COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.3 · Cloud-specific Vulnerabilities

Mestre CyberSec · **Aula 2.3 — Cloud-specific Vulnerabilities** (4:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Ataques da nuvem: DoS com FATURA (gera custo alto — o atacante não derruba o serviço, só deixa caro); authentication bypass (API aberta/exploit); directory traversal (acessar arquivo fora do permitido). O maior risco NUVEM: MISCONFIGURAÇÃO (bucket aberto, IAM permissivo). Respons

💡 Highlights que a prova CompTIA cobra

- Bucket S3 aberto = o vazamento nº1 de cloud
- Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem
- Defesa: CSPM (checa config), IAM com menor privilégio

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'misconfigured bucket exposes data' = cloud misconfig (a falha nº1)
- 'client is responsible for securing data IN the cloud' = shared responsibility

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.3 — Cloud-specific Vulnerabilities)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Configuração Incorreta na Nuvem (Misconfiguration) (N/A)

Recursos de nuvem configurados incorretamente (ex.: buckets S3 abertos, grupos de segurança permissivos) que expõem dados sensíveis. Identificada pela CompTIA como o risco nº1 de segurança em nuvem.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'misconfigured bucket exposes data' or 'publicly accessible storage'. Always choose cloud misconfiguration over more exotic attacks — it is the MOST common cloud breach vector on the exam.*

• Modelo de Responsabilidade Compartilhada (N/A)

Modelo em que o provedor é responsável pela segurança DA nuvem (infraestrutura, hosts, físico) e o cliente é responsável pela segurança NA nuvem (dados, acesso, configurações).

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'Who secures the customer's data?' → Answer is ALWAYS the customer. Remember: 'OF the cloud = Provider; IN the cloud = Customer'. A classic exam trap.*

• Gerenciamento de Postura de Segurança em Nuvem (CSPM)

Ferramenta que avalia continuamente as configurações de nuvem contra boas práticas (ex.: benchmarks CIS) para detectar misconfigurations, violações de compliance e drift.

⚠️ ***Armadilha CompTIA:*** *Question cue: 'Which tool detects misconfigured cloud assets automatically?' → CSPM. Distinguish from CASB (user-facing DLP) and CWPP (workload protection).*

• Negação de Serviço por Faturamento (BDoS / DoS)

Variante de DoS específica de nuvem que esgota o orçamento da vítima gerando consumo massivo de recursos (chamadas de API, storage, banda) em vez de derrubar o serviço.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'attacker drives up cloud costs' or 'service still works but bill is huge'. This is THE cloud-specific DoS scenario — don't confuse with traditional volumetric DDoS.*

• Gerenciamento de Identidade e Acesso (IAM)

Framework que gerencia identidades digitais e suas permissões a recursos de nuvem. A CompTIA enfatiza menor privilégio e RBAC como princípios centrais.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'overly permissive access' or 'user has more rights than needed' → IAM misconfiguration. Pair with Least Privilege Principle — always the answer for access control questions.*

• Travessia de Diretório (Path Traversal) (N/A)

Ataque que usa sequências como '../' para escapar do diretório pretendido e acessar arquivos não autorizados em um servidor ou objeto de storage na nuvem.

⚠️ ***Armadilha CompTIA:*** *Trigger: '../etc/passwd' or 'attacker accesses files outside the web root'. In cloud context, this targets object keys and blob storage paths — input validation is the key mitigation.*

• Bypass de Autenticação (N/A)

Ataque que explora falhas em endpoints de API ou na lógica de autenticação (ex.: validação quebrada de tokens, chaves expostas) para obter acesso sem credenciais válidas.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'attacker accesses cloud resource without password' or 'exposed API key in public repo'. Look for API gateway misconfiguration or hardcoded credentials as the root cause.*

• Bucket S3 Público / Armazenamento de Objetos

Serviço de armazenamento de objetos da AWS frequentemente envolvido em grandes vazamentos quando configurado com acesso público. O exemplo canônico de misconfiguration na prova.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'open S3 bucket' or 'publicly readable object storage' → Cloud Misconfiguration. Know the difference between S3 (object) vs EBS (block) vs EFS (file) — S3 is the one that gets breached via public ACL.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 S3 (Objetos) vs. EBS (Blocos) vs. EFS (Arquivos)

🏠 **Analogia Intuitiva:** O S3 é como um depósito público de caixas postais acessível pela calçada, onde cada pacote ganha uma URL web pública. Já o EBS é um HD interno parafusado na placa-mãe de um único PC, e o EFS é a pasta compartilhada da rede local do escritório.

🔍 **Causa Raiz / Por que foi criado:** O S3 foi desenhado para hospedar arquivos web estáticos acessíveis mundialmente. Se a política do bucket ou ACL for configurada com acesso público acidental, os arquivos confidenciais ficam abertos para qualquer internauta.

🛡️ **Visão do Auditor de GRC:** Verificar se o recurso S3 Block Public Access está ativado em nível de conta inteira e auditar políticas com ferramentas de CSPM.

⚠️ **Como cai na Prova CompTIA:** Trigger: "open S3 bucket" ou "publicly accessible storage". Resposta: Cloud Misconfiguration (o risco nº1 da nuvem na CompTIA).

📌 A Trindade de Nuvem: CSPM vs. CASB vs. CWPP

🏠 **Analogia Intuitiva:** O CSPM é o auditor predial que fiscaliza as configurações e travas do edifício 24h por dia; o CASB é a alfândega/guarda de fronteira na guarita que inspeciona o que os funcionários levam e trazem entre seus notebooks e a nuvem externa; e o CWPP é o segurança armado dentro de cada sala (servidor/contêiner) protegendo o sistema operacional contra malware.

🔍 **Causa Raiz / Por que foi criado:** Ambientes de nuvem são dinâmicos e sofrem desvios de configuração (drift). Sem ferramentas automáticas contínuas, desconfigurações passam despercebidas.

🛡️ **Visão do Auditor de GRC:** Implementar CSPM para monitoramento contínuo de conformidade contra CIS Benchmarks; CASB para DLP de SaaS; CWPP para segurança de runtime em workloads.

⚠️ **Como cai na Prova CompTIA:** Trigger: "detects misconfigured cloud assets automatically" -> CSPM. "User DLP on SaaS" -> CASB. "Workload/host protection" -> CWPP.

📌 Ataques BDoS / EDoS (Billing / Economic Denial of Sustainability)

🏠 **Analogia Intuitiva:** Não tenta derrubar o restaurante; o atacante apenas pede 10.000 pratos caros usando entrega automática. O restaurante continua funcionando a todo vapor, mas no fim do mês a conta da distribuidora vem impagável e quebra o negócio.

🔍 **Causa Raiz / Por que foi criado:** O auto-scaling da nuvem provisiona instâncias e recursos cobrados por consumo (metered) sob demanda. Sem limites máximos, requisições pesadas esgotam o orçamento financeiro.

🛡️ **Visão do Auditor de GRC:** Estabelecer Resource Quotas e tetos máximos de auto-scaling (scaling caps), rate limiting na borda (WAF) e Cost Anomaly Detection com alertas orçamentários imediatos.

⚠️ **Como cai na Prova CompTIA:** Trigger: "attacker drives up cloud costs" ou "service still works but bill is huge". Resposta: Economic Denial of Sustainability (EDoS) / Billing DoS.

📌 Fail Open vs. Fail Closed & Segredos no Cliente

🏠 **Analogia Intuitiva:** Se a catraca do banco ficar sem energia: "Fail Closed" tranca tudo e ninguém passa (prioriza segurança); "Fail Open" solta a trava e todo mundo entra (desastre em TI!). Chave de API embutida no aplicativo de celular é como colar a senha do cofre na capa externa do folheto de propaganda entregue na rua.

🔍 **Causa Raiz / Por que foi criado:** Tratar chaves ou tokens incorporados no cliente como segredos, ou arquitetar APIs que respondem dados completos quando nenhum cabeçalho de autorização é enviado.

🛡️ **Visão do Auditor de GRC:** Exigir autenticação do lado do servidor (Server-Side Authentication), mutual TLS ou tokens efêmeros; e adotar arquitetura de Negação por Padrão (Deny by Default / Fail Closed).

⚠️ **Como cai na Prova CompTIA:** Trigger: "API returns data when Authorization header is omitted" -> Authentication bypass via Fail Open defect.

📌 Directory Traversal & Canonicalização

🏠 **Analogia Intuitiva:** O comando ../ é como dar um passo para trás no corredor para sair da sala de visitas e entrar no cofre da diretoria. Canonicalizar é passar o endereço a limpo para o nome formal e conferir se ele ainda está dentro do perímetro autorizado.

🔍 **Causa Raiz / Por que foi criado:** Falta de validação e sanitização do caminho solicitado pelo usuário, permitindo sequências ../ para escapar da pasta web e ler arquivos do sistema operacional (ex: /etc/passwd).

🛡️ **Visão do Auditor de GRC:** Validar caminhos canônicos contra allowlists de arquivos permitidos ou usar identificadores opacos indexados.

⚠️ **Como cai na Prova CompTIA:** Trigger: "../etc/passwd" ou "attacker accesses files outside web root". Mitigação: Canonicalization + allowlist de arquivos.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Vazamento público de dados em armazenamento na nuvem	**Cloud Misconfiguration (Bucket S3 público)**
Quem aplica o patch de segurança no Windows de uma VM na nuvem?	**O Cliente (Modelo de Responsabilidade Compartilhada em IaaS)**
Ferramenta que audita automaticamente configurações contra normas e CIS benchmarks	**CSPM (Cloud Security Posture Management)**
Fatura da nuvem veio estratosférica sem derrubar o serviço	**BDoS / EDoS (Economic Denial of Sustainability)**
Regra IAM com Action: "*" e Resource: "*"	**Violação do Menor Privilégio (Excessive Wildcard Permissions)**
Uso de ../ para escapar da pasta e ler arquivos do servidor	**Directory Traversal (resolvido via Canonicalization + Allowlist)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de comércio eletrônico de médio porte opera sua loja na AWS com grupos de auto scaling, CDN e funções serverless. Em um fim de semana de feriado, a fatura mensal salta de cerca de US$ 9.000 para mais de US$ 260.000. O monitoramento não mostra indisponibilidade do serviço, os tempos de resposta estão normais e o tráfego vem de milhares de IPs residenciais que chamam repetidamente os endpoints mais caros em processamento, de busca e redimensionamento de imagens. O CEO quer saber o que aconteceu. Qual ataque específico de nuvem descreve melhor esse evento?

A) Um ataque de negação de serviço volumétrico que saturou o balanceador de carga e tirou a loja do ar

B) Um ataque de negação de sustentabilidade econômica, no qual o adversário forçou o consumo de recursos medidos para inflar a fatura

C) Um ataque de directory traversal que permitiu ao adversário ler arquivos fora do diretório web

D) Uma campanha de credential stuffing que comprometeu contas de clientes e gerou reembolsos

QUESTÃO 2 · CENÁRIO DE EXAME

Um engenheiro de nuvem em uma conta de desenvolvimento cria um bucket de armazenamento de objetos para imagens de produtos e aplica uma política que concede leitura a todos, para que o site de marketing possa incorporar as imagens. Três semanas depois, a equipe de segurança recebe um alerta de que o mesmo bucket também contém exportações noturnas de faturas de clientes, e esses objetos podem ser recuperados por qualquer pessoa que tenha a URL. Qual afirmação descreve a causa raiz e a ação corretiva adequada?

A) O provedor violou o modelo de responsabilidade compartilhada ao não criptografar o bucket; a correção é abrir um chamado de suporte

B) A política/ACL do bucket estava mal configurada, expondo os dados; a correção é bloquear o acesso público, remover a política pública, restringir o acesso a principals específicos e monitorar a configuração

C) O bucket foi comprometido por meio de directory traversal; a correção é sanitizar o parâmetro de URL usado pelo site de marketing

D) Os objetos foram expostos por um bypass de autenticação na API de armazenamento; a correção é rotacionar as chaves da conta de armazenamento

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa migra uma aplicação interna para infraestrutura como serviço. O provedor fornece o hypervisor, o armazenamento e a malha de rede; a equipe da empresa constrói as máquinas virtuais, instala o sistema operacional convidado e gerencia a aplicação. Seis meses depois, atacantes exploram uma vulnerabilidade de kernel não corrigida em um desses sistemas operacionais convidados e se movem lateralmente até um banco de dados. Segundo o modelo de responsabilidade compartilhada, qual parte é responsável por essa falha?

A) O provedor de nuvem, porque vulnerabilidades de kernel fazem parte do hypervisor que ele opera

B) O cliente, porque a correção do sistema operacional convidado é responsabilidade do cliente em infraestrutura como serviço

C) Ambas as partes igualmente, porque o modelo sempre divide cada controle 50/50

D) Nenhuma das partes, porque kernels sem correção estão fora do escopo do modelo de responsabilidade compartilhada

QUESTÃO 4 · CENÁRIO DE EXAME

O endpoint de download de faturas de um provedor SaaS é implementado como um serviço Python em contêiner. Um testador de invasão envia uma requisição com um parâmetro de arquivo contendo sequências ../ repetidas e recebe o conteúdo de /etc/passwd, um arquivo bem fora do diretório de faturas pretendido. A aplicação é executada como usuário não root em um contêiner com montagem de host somente leitura. Qual controle impede mais diretamente esse tipo de ataque?

A) Habilitar versionamento de objetos e políticas de ciclo de vida no bucket que armazena as faturas

B) Canonicalizar o caminho solicitado e validá-lo contra uma lista de permissões de arquivos ou um diretório base fixo antes de abri-lo

C) Exigir autenticação multifator para todos os usuários que baixam faturas

D) Aumentar os limites de CPU e memória do contêiner para que as requisições expirem antes de concluir

QUESTÃO 5 · CENÁRIO DE EXAME

Durante uma revisão de API, um testador descobre que o endpoint GET /api/v2/internal/users retorna o diretório completo de usuários quando o cabeçalho Authorization é totalmente omitido. Quando um token válido, mas sem privilégios, é enviado, o endpoint retorna corretamente 403. O código verifica o token apenas dentro do ramo que trata operações privilegiadas. Qual vulnerabilidade isso representa?

A) Um bypass de autenticação em que o controle de autorização falha aberto quando as credenciais estão ausentes

B) Uma falha de directory traversal causada pelo segmento de caminho /internal na URL

C) Um ataque de negação de serviço por faturamento causado por consultas caras ao diretório

D) Uma falha de cross-site scripting na resposta JSON devolvida ao cliente

QUESTÃO 6 · CENÁRIO DE EXAME

Um arquiteto de segurança precisa dar à liderança visibilidade contínua e automatizada sobre recursos de nuvem mal configurados em dois provedores e três contas: armazenamento exposto publicamente, políticas de identidade excessivamente permissivas, volumes não criptografados e registro desativado. A equipe quer os achados priorizados segundo um benchmark e integrados ao fluxo de tickets existente. Qual capacidade atende melhor a esse requisito?

A) Uma ferramenta de gerenciamento de postura de segurança em nuvem (CSPM) que avalia continuamente as configurações segundo benchmarks e reporta desvios

B) Um firewall de aplicação web posicionado à frente dos balanceadores públicos

C) Uma plataforma de prevenção de perda de dados que inspeciona e-mails e transferências de arquivos de saída

D) Um agente de detecção de intrusão baseado em host instalado em cada máquina virtual

QUESTÃO 7 · CENÁRIO DE EXAME

Uma auditoria descobre que a função de identidade usada pelo pipeline de integração contínua tem uma política anexada com Action '*' e Resource '*' na conta de produção. O pipeline só precisa enviar imagens de contêiner para um registro e ler um caminho de segredos. Qual mudança reduz melhor o risco?

A) Rotacionar as chaves de acesso do pipeline a cada 30 dias e mantê-las nas variáveis de ambiente do pipeline

B) Exigir autenticação multifator na conta de serviço do pipeline e reduzir a duração da sessão

C) Substituir a política com curinga por permissões de menor privilégio limitadas às ações específicas do registro e ao único caminho de segredos

D) Habilitar registro detalhado na função do pipeline e revisar os logs mensalmente

QUESTÃO 8 · CENÁRIO DE EXAME

Uma revisão de postura em nuvem de uma empresa de saúde retorna quatro achados na conta de produção. Qual achado deve ser remediado primeiro por representar o maior risco imediato de exposição de dados?

A) Um bucket de armazenamento de objetos com registros de pacientes tem uma política que concede leitura a todos os principals

B) O versionamento de objetos está desabilitado no bucket que armazena registros de pacientes

C) O registro de acesso desse bucket é encaminhado para um arquivo de logs com retenção de 90 dias

D) O balanceador de carga aceita TLS 1.2 além de TLS 1.3

QUESTÃO 9 · CENÁRIO DE EXAME

Após um incidente de negação de sustentabilidade econômica em que atacantes dispararam milhares de eventos caros de auto scaling a partir de poucas redes de origem, uma empresa quer controles que limitem o dano financeiro sem quebrar picos legítimos de tráfego. Qual combinação é mais apropriada?

A) Cotas de recursos e limites máximos de tamanho no auto scaling, limitação de taxa por cliente na borda e detecção de anomalias de custo com alertas de orçamento

B) Desabilitar o auto scaling e o cache de CDN para que o uso de recursos permaneça constante

C) Exigir MFA para todos os usuários do console de nuvem e rotacionar credenciais de root

D) Habilitar versionamento de armazenamento e object lock em todos os buckets

QUESTÃO 10 · CENÁRIO DE EXAME

Uma equipe de banco móvel publica um aplicativo que chama seu próprio backend usando uma chave de API embutida no binário compilado do cliente e no bundle JavaScript público. Um pesquisador extrai a chave e a usa para chamar os endpoints administrativos da mesma API, que aceitam a chave como prova suficiente de identidade. Qual fraqueza foi explorada?

A) Um directory traversal no manipulador de arquivos estáticos do gateway de API

B) Um bypass de autenticação específico de nuvem causado por tratar um segredo observável no lado do cliente como autenticador

C) Um ataque de negação de sustentabilidade econômica que inflou os custos da API

D) Uma lacuna de responsabilidade compartilhada em que o provedor não criptografou o tráfego da API

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Um ataque de negação de sustentabilidade econômica, no qual o adversário forçou o consumo de recursos medidos para inflar a fatura

O serviço permaneceu disponível e o desempenho ficou normal, mas recursos de nuvem medidos (computação, instâncias de auto scaling, invocações serverless, tráfego de saída) foram consumidos, inflando o custo. Isso é negação de sustentabilidade econômica (EDoS), também chamada de DoS de faturamento ou financeiro: o atacante não precisa derrubar o serviço, apenas torná-lo caro. DDoS volumétrico degradaria a disponibilidade, directory traversal é uma falha de acesso a arquivos e credential stuffing ataca contas, não gastos com nuvem.

Questão 2: Alternativa B — A política/ACL do bucket estava mal configurada, expondo os dados; a correção é bloquear o acesso público, remover a política pública, restringir o acesso a principals específicos e monitorar a configuração

Políticas e ACLs de leitura pública são a misconfiguração clássica de nuvem. O cliente controla a classificação dos dados, a política do bucket, as ACLs e as configurações de bloqueio de acesso público, mesmo quando o provedor gerencia a infraestrutura física — logo, a responsabilidade é do cliente. A remediação correta combina bloquear o acesso público, remover a política permissiva, conceder acesso de menor privilégio a principals específicos e detectar desvios continuamente (por exemplo, com uma ferramenta CSPM).

Questão 3: Alternativa B — O cliente, porque a correção do sistema operacional convidado é responsabilidade do cliente em infraestrutura como serviço

Em IaaS o provedor protege instalações físicas, hardware, hypervisor e malha de rede, enquanto o cliente protege tudo do sistema operacional convidado para cima: correções do SO, hardening, contas, código da aplicação e dados. Portanto, a vulnerabilidade de kernel é uma falha de controle do cliente. O modelo não é uma divisão 50/50 e não exclui a aplicação de correções.

Questão 4: Alternativa B — Canonicalizar o caminho solicitado e validá-lo contra uma lista de permissões de arquivos ou um diretório base fixo antes de abri-lo

Este é um directory traversal (path traversal): a entrada fornecida pelo usuário chega ao caminho do sistema de arquivos sem validação. A correção principal é resolver o caminho para sua forma canônica e confirmar que ele permanece dentro do diretório base pretendido ou, melhor, referenciar arquivos por um identificador opaco mapeado a uma lista de permissões. Versionamento, MFA e limites maiores de recursos não afetam o tratamento de caminhos.

Questão 5: Alternativa A — Um bypass de autenticação em que o controle de autorização falha aberto quando as credenciais estão ausentes

O endpoint concede acesso quando nenhuma credencial é apresentada, o que é um defeito de autenticação/autorização do tipo fail-open — uma forma de bypass de autenticação (controle de acesso quebrado). Projetos seguros negam por padrão e exigem uma identidade validada antes de retornar qualquer dado. Directory traversal, DoS de faturamento e XSS não descrevem uma decisão de autorização que assume 'permitir' por padrão.

Questão 6: Alternativa A — Uma ferramenta de gerenciamento de postura de segurança em nuvem (CSPM) que avalia continuamente as configurações segundo benchmarks e reporta desvios

O gerenciamento de postura de segurança em nuvem (CSPM) examina continuamente contas de nuvem em busca de misconfigurações e desvios de conformidade — exatamente os achados listados. Um WAF protege contra ataques na camada web, DLP foca em exfiltração de dados e IDS baseado em host monitora atividade em tempo de execução em uma única máquina; nenhum fornece avaliação de configuração multiconta.

Questão 7: Alternativa C — Substituir a política com curinga por permissões de menor privilégio limitadas às ações específicas do registro e ao único caminho de segredos

O achado é a permissão excessiva; a correção é o menor privilégio. Uma função com '*'/'*' pode criar, modificar ou excluir qualquer recurso da conta, de modo que um pipeline comprometido equivale à tomada de controle total da conta. Rotação de chaves, MFA e logging são controles úteis de defesa em profundidade, mas não removem o raio de impacto de uma identidade com privilégios excessivos.

Questão 8: Alternativa A — Um bucket de armazenamento de objetos com registros de pacientes tem uma política que concede leitura a todos os principals

Um bucket legível por qualquer pessoa na internet contendo dados regulados é uma exposição ativa — a internet pode recuperar os registros agora — e esse tipo de misconfiguração é a causa raiz mais comum de vazamentos de dados na nuvem. Versionamento, escolhas de retenção de logs e a permissão de TLS 1.2 são questões de hardening, não exposições ativas.

Questão 9: Alternativa A — Cotas de recursos e limites máximos de tamanho no auto scaling, limitação de taxa por cliente na borda e detecção de anomalias de custo com alertas de orçamento

A negação de sustentabilidade econômica é combatida com governança de consumo: cotas rígidas e limites de escalonamento, limitação de taxa e mitigação de bots na borda para reduzir a alavancagem do atacante, e detecção de anomalias de custo com alertas de orçamento para aviso antecipado. Remover o auto scaling prejudica a disponibilidade legítima, e MFA, rotação de chaves, versionamento e object lock tratam de identidade e integridade de dados, não de gastos.

Questão 10: Alternativa B — Um bypass de autenticação específico de nuvem causado por tratar um segredo observável no lado do cliente como autenticador

Segredos enviados ao cliente são observáveis por qualquer pessoa e não podem servir como autenticação. Como a API aceitava essa chave sozinha como prova de identidade, o atacante contornou a autenticação e alcançou funções administrativas. A correção é identidade no lado do servidor (tokens vinculados a um usuário, mTLS ou credenciais de curta duração), além de tratar qualquer segredo de cliente vazado como comprometido. As demais opções descrevem classes de vulnerabilidade diferentes.